

Lab 3 - Phishing Email Investigation

Safe Simulated Email Analysis and IOC Extraction

Attribute	Details
Lab type	SOC / Email Security Investigation
Scenario	Simulated phishing email
Environment	Windows 11 VM / text-based analysis
Objective	Identify phishing indicators, extract IOCs, and document findings

1. Objective

Investigate a safe simulated phishing email using a SOC analyst workflow focused on sender anomalies, social-engineering indicators, suspicious links, authentication results, IOC extraction, MITRE ATT&CK mapping, and a final analyst conclusion.

2. Simulated Email

Field	Observed value
From	Microsoft 365 Security <security-alert@micrs0ft-support.example>
To	employee@example.com
Subject	URGENT: Your Microsoft 365 account will be suspended
Reply-To	account-verification@secure-mail.example

The message claimed unusual activity and threatened account suspension within 24 hours unless the user verified their identity using a supplied link.

3. Header and Sender Analysis

Indicator	Interpretation
Lookalike sender	The domain uses 0 in place of o.
Reply-To mismatch	Reply-To does not align with the visible sender.
SPF: fail	Sending server not authorized for the claimed domain.
DKIM: none	No DKIM signature present.
DMARC: fail	Authentication/alignment requirements not satisfied.

4. URL and Social Engineering

The message used urgency, threats of account suspension, immediate-verification language, and the URL <https://login-microsoft.example/verify>. HTTPS alone does not make a site trustworthy.

5. Indicators of Compromise

IOC Type	Value
Sender email	security-alert@micrs0ft-support.example
Reply-To	account-verification@secure-mail.example
URL	https://login-microsoft.example/verify
Received IP (simulated)	203.0.113.50

6. MITRE ATT&CK Mapping

T1566.002 - Phishing: Spearphishing Link. The email attempted to direct the recipient to a suspicious verification link. Credential theft was a plausible objective, but there was no evidence that credentials were submitted or stolen.

7. Recommended SOC Response

- Quarantine or remove the message.
- Block sender/domain/URL indicators.
- Search for similar messages across other mailboxes.
- Check link-click and sign-in telemetry.

- Escalate if evidence of compromise appears.

8. Conclusion

Multiple independent indicators were consistent with phishing. The lab demonstrated sender validation, header analysis, URL review, IOC extraction, authentication-result interpretation, ATT&CK mapping, and evidence-based reporting.